

Password Spray Investigation Playbook

Microsoft Learn field guide for identity-focused incident response

Condensed, non-verbatim operational guide

Purpose	Quick-reference guide for identifying, scoping, investigating, recovering from, and documenting password spray attacks in Microsoft identity environments.
Primary audience	SecOps analysts, identity administrators, incident responders, Microsoft Entra administrators, federation administrators, and IT operations teams.
Reference source	https://learn.microsoft.com/en-us/security/operations/incident-response-playbook-password-spray
Generated	2026-07-02
Use note	
This document is a condensed field guide based on Microsoft Learn guidance. Use the linked Microsoft Learn article as the authoritative source for the latest workflow images, prerequisites, role requirements, portal paths, and command syntax.	

Prepared for: Muataz Awad | Microsoft Security customer-facing readiness

1. Investigation objective and expected outcome

A password spray investigation should determine whether attackers attempted or achieved valid credential use across many accounts, which accounts were targeted or compromised, what identity and authentication controls responded, and what recovery actions are required to reduce further risk.

Outcome statement

At the end of the investigation, the analyst should be able to answer: What sign-in pattern triggered the suspicion? Which accounts were targeted? Was any credential validated successfully? Which IPs, locations, user agents, protocols, or applications were involved? Which users require remediation? What evidence supports the final verdict?

2. At-a-glance workflow

Step	Phase	Focus
1	Confirm the alert and attack pattern	Review the suspicious sign-in activity, error codes, IP addresses, locations, applications, user agents, protocols, and impacted users.
2	Establish targeted and compromised scope	Separate broad targeting from successful credential validation. Prioritize accounts with successful sign-ins, unusual properties, or high privilege.
3	Correlate identity evidence	Review Microsoft Entra sign-in logs, risk detections, audit activity, ADFS/security logs where applicable, and SIEM/Sentinel data.
4	Review downstream activity	Inspect mailbox, file, app, endpoint, and administrative activity after suspicious sign-ins to determine whether accounts were misused.
5	Contain and recover	Block or challenge suspicious access, reset passwords, require MFA/security info re-registration, revoke sessions, and address weak authentication paths.
6	Document and improve controls	Record evidence, timeline, users impacted, recovery actions, detection gaps, and improvements to password protection, MFA, Conditional Access, and monitoring.

3. Readiness prerequisites

Microsoft Entra monitoring: Ensure Microsoft Entra sign-in and audit logging are available and retained for the investigation window.

AD FS logging, if federated: For AD FS environments, verify auditing level and send AD FS and security logs to a SIEM so federation activity can be correlated with Microsoft Entra sign-in data.

Security logging: Confirm security auditing is enabled on relevant AD FS servers and that logs are centrally collected.

SIEM/Sentinel correlation: Use Microsoft Sentinel, Azure Monitor, or another SIEM for cross-source correlation, longer retention, and hunting across identity signals.

Roles and permissions: Ensure investigators have appropriate access to Microsoft Entra sign-in/audit logs, identity risk data, federation logs, endpoint/app/mailbox evidence, and response actions.

Baseline controls: Validate MFA coverage, Conditional Access, smart lockout, password protection, legacy authentication controls, and break-glass account handling before incidents happen.

Microsoft Learn prerequisite highlight

The Microsoft Learn playbook explicitly calls out setup for logs and alerts, Microsoft Entra monitoring, and AD FS logging. For AD FS 2016, the source notes that basic auditing is enabled by default and that verbose auditing logs all events but can generate significant volume.

4. Investigation checklist

Initial triage

- ☐ Review alert details and identify the trigger: failed attempts, successful sign-ins, IPs, locations, apps, protocols, or risk detections.
- ☐ Capture the investigation window and preserve raw telemetry before retention windows expire.
- ☐ Identify whether the activity is isolated to one IP/location or distributed across infrastructure.

Target and account scope

- ☐ Build the list of targeted users and distinguish failed-only accounts from accounts with successful authentication.
- ☐ Prioritize privileged users, service accounts, high-value business users, shared mailboxes, and accounts without MFA.
- ☐ Check whether targeted users have recent password changes, MFA changes, security info updates, app consent, or suspicious administrative activity.

Identity and federation evidence

- ☐ Review Microsoft Entra sign-in logs and risk detections for unfamiliar properties, malicious IPs, password spray, and successful credential validation.
- ☐ Review Microsoft Entra audit logs for changes after suspicious sign-ins.
- ☐ For federated environments, correlate AD FS and security logs with Microsoft Entra sign-ins and SIEM data.

Downstream activity

- ☐ Review mailbox access, suspicious inbox rules, forwarding, and sending patterns for accounts with successful suspicious sign-ins.
- ☐ Review file access, app activity, endpoint telemetry, and cloud app activity for post-authentication misuse.
- ☐ Identify whether the attacker created persistence, changed credentials, registered MFA, or accessed sensitive data.

Containment and recovery

- ☐ Block or challenge suspicious access based on user/sign-in risk and business impact.
- ☐ Reset passwords for compromised users and require strong verification before restoring access.
- ☐ Revoke sessions/tokens where compromise is suspected.
- ☐ Require users to re-register MFA/security info if attacker tampering is suspected.
- ☐ Tune prevention controls: MFA, Conditional Access, legacy auth blocking, smart lockout, and password protection.

5. Detailed investigation guidance

5.1 Confirm the signal

- Start with the alert or detection and capture the exact users, IP addresses, locations, applications, user agents, protocols, and result/error codes involved.
- Look for the classic spray pattern: many accounts attempted from common infrastructure with low attempts per account, and prioritize any successful sign-ins.
- Treat successful credential validation differently from failed-only activity because it may require immediate account remediation.

5.2 Scope targeted and compromised accounts

- Build a working table of all targeted users, their role/sensitivity, MFA status if available, successful/failed sign-in status, and required action.
- Prioritize accounts with privileged roles, access to sensitive data, weak authentication posture, or successful suspicious sign-ins.
- Check whether targeted users show anomalous post-authentication actions across mail, files, apps, endpoints, or administration.

5.3 Correlate Microsoft Entra and federation logs

- Use Microsoft Entra sign-in logs to inspect result codes, source IPs, device/browser/user-agent details, conditional access results, authentication requirements, and risk detections.
- Use Microsoft Entra audit logs for security information registration, MFA method changes, password changes, application consent, role assignments, and administrative modifications.
- Where AD FS is used, collect verbose AD FS event data and security logs into the SIEM to correlate federation activity with Microsoft Entra ID.

5.4 Review downstream activity after suspicious sign-ins

- For accounts with successful suspicious sign-ins, review mailbox access, sending behavior, inbox forwarding, inbox manipulation rules, and suspicious file or app access.
- Check endpoint and cloud app telemetry for exfiltration, persistence, or lateral movement indicators.
- Document whether downstream activity supports compromise, benign use, or inconclusive status.

5.5 Recover and reduce recurrence

- Use risk-based remediation where available: self-service password reset, administrator-initiated password reset, user blocking, session revocation, and MFA/security info re-registration as appropriate.
- Harden controls that reduce password spray success: enforce MFA, require phishing-resistant authentication for privileged access where practical, block legacy authentication, tune smart lockout, and strengthen password protection.
- Update detection logic and playbooks based on the actual attacker infrastructure, applications, protocols, and user populations observed.

6. Handy command and query starting points

Reminder

Validate command syntax and permissions against the latest Microsoft Learn docs before running in a customer tenant. Scope permissions and use least privilege.

Use case	Example / location	Why it matters
View AD FS audit level	Get-AdfsProperties	Shows the current AD FS properties, including audit configuration.
Set AD FS audit level	Set-AdfsProperties -AuditLevel <None Basic Verbose>	Verbose logs all events, but Microsoft Learn notes this produces significant information per request.
Enable security auditing for AD FS-generated application events	auditpol.exe /set /subcategory:"Application Generated" /failure:enable /success:enable	Enables success and failure auditing for application generated events.
Review risky sign-ins / users	Microsoft Entra admin center > Protection > Identity Protection	Use Identity Protection risk views to investigate risky users, detections, and sign-ins.
Revoke sessions for suspected compromise	Revoke-MgUserSignInSession -UserId <user-id-or-upn>	Forces re-authentication after suspected account compromise or credential validation.

7. Evidence matrix

Question	Helpful evidence sources
Was this actually password spray?	Sign-in logs, failed attempt distribution, source IPs, result/error codes, user count per source, risk detections
Did any credential validate successfully?	Successful sign-ins tied to the spray pattern, Identity Protection detections, sign-in risk details
Which accounts are most sensitive?	Directory roles, privileged groups, app permissions, mailbox/data access, admin activity
Was the account abused after sign-in?	Mailbox audit, file access, app activity, endpoint telemetry, cloud app activity, audit logs
Was MFA/security info tampered with?	Microsoft Entra audit logs, authentication method changes, security info registration events
Was access contained?	User block state, password reset status, session revocation output, Conditional Access results, risk remediation state
What prevention gap allowed risk?	Legacy authentication usage, MFA gaps, weak passwords, Conditional Access gaps, smart lockout/password protection settings

8. Closure notes template

- ☐ Incident summary: suspected password spray pattern, detection source, and affected authentication systems.
- ☐ Timeline: first observed failed attempts, successful sign-ins, detection time, containment time, recovery completion.
- ☐ Scope: targeted users, compromised users, privileged/high-value accounts, IPs, locations, apps, protocols, and devices.
- ☐ Evidence reviewed: Microsoft Entra sign-in logs, Identity Protection detections, audit logs, AD FS/SIEM data, mailbox/app/file/endpoint activity.
- ☐ Verdict: true positive, false positive, benign operational event, or inconclusive with rationale.
- ☐ Actions completed: user blocks, password resets, session revocation, MFA/security info re-registration, policy changes, and communication.
- ☐ Follow-up recommendations: blocking legacy authentication, strengthening MFA/Conditional Access, validating smart lockout, improving telemetry retention, and tuning detections.

9. Authoritative sources

Primary Microsoft Learn article: [Password spray investigation | Microsoft Learn](#)

Related Microsoft Learn article for Identity Protection risk remediation: [Investigate risk with Microsoft Entra ID Protection | Microsoft Learn](#)

This field guide does not replace the official articles. Always reference Microsoft Learn for the latest workflow diagrams, role/permission details, portal paths, and command syntax.